

Session Fixation and Hijacking



Session Hijacking

Session Fixation





Session Fixation and Hijacking



تهیه شده توسط تیم TryHackBox

The Chaos



لینک زیر جهت حمایت از جامعه آموزش رایگان :

<https://daramet.com/TryHackBox>

ما را به دوستانتان معرفی کنید .

دیگر کانال ها و شبکه های اجتماعی ما را دنبال کنید:

کانال های تلگرام ما

آموزش تست نفوذ و Red Team :

[@TryHackBox](#)

رودمپ های مختلف:

[@TryHackBoxOfficial](#)

داستان های هک:

[@TryHackBoxStory](#)

آموزش برنامه نویسی:

[@TryCodeBox](#)

رادیو زیروپاد (پادکست ها):

[@RadioZeroPod](#)

TryHackBox

اینستاگرام :

<http://www.instagram.com/TryHackBox>

یوتیوب:

<https://youtube.com/@tryhackbox>



session چیست؟

یک جلسه (session) به دوره‌ای اشاره دارد که طی آن کاربر با یک برنامه یا سرویس وب تعامل دارد، که معمولاً با ورود کاربر یا شروع یک فعالیت شروع می‌شود و با خروج یا غیرفعال شدن او پایان می‌یابد.

Key Characteristics of a Session

۱. **تعامل کاربر:** یک جلسه، تعاملات کاربر، مانند مرور صفحات، اضافه کردن اقلام به سبد خرید یا ارسال فرم‌ها را ردیابی می‌کند. این به برنامه اجازه می‌دهد تا زمینه مربوط به اقدامات کاربر را حفظ کند.
۲. **مدیریت وضعیت:** از آنجایی که برنامه‌های وب بدون وضعیت هستند، جلسات با ذخیره اطلاعات مربوط به فعالیت و تنظیمات کاربر در طول بازدیدشان، به مدیریت وضعیت کمک می‌کنند. این امر یک تجربه یکپارچه را فراهم می‌کند.
۳. **مدت زمان:** جلسات می‌توانند برای مدت زمان‌های مختلفی ادامه داشته باشند. آنها ممکن است پس از یک دوره عدم فعالیت (زمان پایان جلسه) منقضی شوند یا زمانی که کاربر به صراحت از سیستم خارج شود، پایان یابند.
۴. **ذخیره‌سازی جلسه:** اطلاعات مربوط به یک جلسه اغلب در سرور (مثلاً در حافظه یا پایگاه داده) ذخیره می‌شوند و با یک شناسه جلسه منحصر به فرد مرتبط می‌شوند که به مرورگر کاربر ارسال می‌شود.
۵. **ملاحظات امنیتی:** جلسات می‌توانند در برابر حملات آسیب‌پذیر باشند، بنابراین اجرای اقدامات امنیتی (مانند کوکی‌های امن و زمان پایان جلسه) برای محافظت از داده‌های کاربر و جلوگیری از دسترسی غیرمجاز ضروری است.



انواع Session

- User Sessions :

این جلسات زمانی ایجاد می‌شوند که کاربران وارد یک برنامه می‌شوند و امکان شخصی‌سازی تجربیات را بر اساس پروفایل‌هایشان فراهم می‌کنند.

- Shopping Sessions :

در تجارت الکترونیک، جلسات، اقلام اضافه شده به سبد خرید و تنظیمات کاربر را تا زمان تکمیل خرید ردیابی می‌کنند.

- API Sessions :

برای API ها، جلسات ممکن است برای حفظ احراز هویت و وضعیت کاربر در طول فراخوانی‌های API استفاده شوند.

مثال روند کار

۱. شروع جلسه: کاربر از یک وبسایت بازدید می‌کند و وارد سیستم می‌شود. سرور یک شناسه جلسه ایجاد می‌کند و داده‌های جلسه (مثلاً اطلاعات کاربر) را ذخیره می‌کند.

TryHackBox

۲. اقدامات کاربر: همزمان با پیمایش کاربر در سایت، شناسه جلسه او با هر درخواست ارسال می‌شود و به سرور اجازه می‌دهد داده‌های جلسه خود را بازیابی کرده و پاسخ‌ها را شخصی‌سازی کند.



۳. **پایان جلسه:** جلسه زمانی پایان می‌یابد که کاربر از سیستم خارج شود یا پس از یک دوره عدم فعالیت، که در آن زمان شناسه جلسه نامعتبر می‌شود و هرگونه داده مرتبط ممکن است پاک یا بایگانی شود.

اهمیت Sessions

جلسات (Session) برای ارائه یک تجربه کاربری روان و شخصی‌سازی‌شده در برنامه‌های وب بسیار مهم هستند. آن‌ها تعاملات حالت‌مند (stateful) را امکان‌پذیر می‌کنند و به کاربران اجازه می‌دهند بدون از دست دادن اطلاعات، در برنامه‌ها پیمایش کنند و در عین حال مکانیسم‌هایی برای امنیت و مدیریت داده‌ها نیز فراهم می‌کنند.

session ID چیست ؟

شناسه جلسه، شناسه‌ای منحصر به فرد است که به جلسه کاربر در یک وبسایت یا برنامه اختصاص داده می‌شود. این شناسه به ردیابی و مدیریت تعاملات کاربر در طول یک بازدید واحد کمک می‌کند. هنگامی که کاربر به یک سرویس دسترسی پیدا می‌کند، سرور یک شناسه جلسه ایجاد می‌کند که اغلب در یک کوکی یا URL ذخیره می‌شود. این شناسه به سرور اجازه می‌دهد تا تنظیمات کاربر، وضعیت احراز هویت و سایر اطلاعات مربوط به جلسه را هنگام پیمایش کاربر در صفحات یا ویژگی‌های مختلف به خاطر بسپارد. پس از پایان جلسه (به عنوان مثال، هنگامی که کاربر از سیستم خارج می‌شود یا زمان جلسه به پایان می‌رسد)، شناسه جلسه نامعتبر می‌شود.



هدف Session IDs

۱. **شناسایی کاربر:** شناسه‌های جلسه به شناسایی کاربران بین درخواست‌ها کمک می‌کنند. وقتی کاربر وارد سیستم می‌شود یا یک جلسه را شروع می‌کند، سرور یک شناسه جلسه منحصر به فرد برای پیگیری فعالیت او تولید می‌کند.
۲. **مدیریت وضعیت:** برنامه‌های وب ذاتاً بدون وضعیت هستند (HTTP بدون وضعیت است). شناسه‌های جلسه به توسعه‌دهندگان اجازه می‌دهند وضعیت کاربر (مثلاً ورود به سیستم، محتوای سبد خرید) را در چندین درخواست حفظ کنند.
۳. **شخصی‌سازی:** شناسه‌های جلسه می‌توانند اطلاعات خاص کاربر، مانند تنظیمات یا ترجیحات را ذخیره کنند و تجربه شخصی‌تری را فراهم کنند.

How Session IDs Work

۱. **ایجاد جلسه:** وقتی کاربر یک جلسه را شروع می‌کند (مثلاً با ورود به سیستم)، سرور یک شناسه جلسه منحصر به فرد ایجاد می‌کند که اغلب از مقادیر تصادفی یا هش استفاده می‌کند.
۲. **ذخیره‌سازی جلسه:** شناسه جلسه معمولاً به کلاینت ارسال می‌شود و در یک کوکی ذخیره می‌شود یا در URL گنجانده می‌شود. سرور همچنین ممکن است داده‌های جلسه را در حافظه، پایگاه‌های داده یا ذخیره‌سازی سمت سرور نگهداری کند.
۳. **ردیابی جلسه:** همانطور که کاربر در سایت پیمایش می‌کند، مرورگر او با هر درخواست، شناسه جلسه را به سرور ارسال می‌کند. سرور از این شناسه برای بازیابی داده‌های جلسه مرتبط استفاده می‌کند.



۴. پایان جلسه: یک جلسه می تواند به چندین روش پایان یابد:

- خروج کاربر.

- پایان زمان جلسه پس از یک دوره عدم فعالیت.

- سرور صراحتاً جلسه را نامعتبر می کند.

Security Considerations

- Session Hijacking :

مهاجمان ممکن است سعی کنند شناسه های نشست را بدزدند (مثلاً از طریق cross-site scripting یا شنود شبکه). استفاده از HTTPS می تواند با رمزگذاری داده های در حال انتقال، به کاهش این خطر کمک کند.

- Session Fixation :

در این حمله، مهاجم قبل از ورود کاربر، شناسه نشست را تنظیم می کند. پس از ورود، مهاجم می تواند از آن شناسه برای جعل هویت کاربر استفاده کند. سرورها باید شناسه های نشست را پس از ورود دوباره تولید کنند تا از این امر جلوگیری شود.

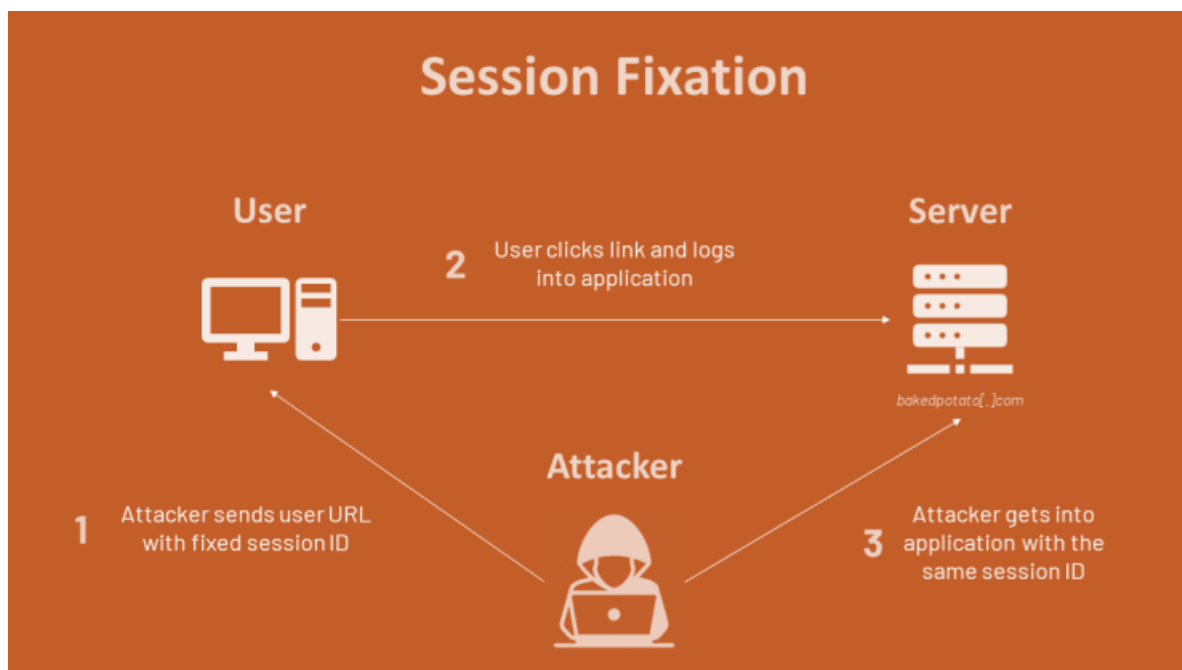
- Expiration and Invalidation :

پیاده سازی مهلت های زمانی و اجازه دادن به کاربران برای خروج از سیستم می تواند به کاهش خطرات کمک کند. پس از مهلت زمانی یا خروج، شناسه نشست باید نامعتبر شود.

- Secure Cookies :



استفاده از ویژگی‌هایی مانند «HttpOnly» و «Secure» روی کوکی‌ها می‌تواند به محافظت از شناسه‌های جلسه در برابر دسترسی جاوا اسکریپت یا انتقال از طریق اتصالات رمزگذاری نشده کمک کند.



Best Practices

- استفاده از مقادیر تصادفی قوی: با استفاده از الگوریتم‌های امن، شناسه‌های جلسه را تولید کنید تا از غیرقابل پیش‌بینی بودن آنها اطمینان حاصل شود.
- تولید مجدد شناسه‌ها: شناسه جلسه را پس از رویدادهای خاص (مثلاً ورود به سیستم) تغییر دهید تا خطر تثبیت کاهش یابد.
- محدود کردن طول عمر جلسه: زمان‌های انتظار معقول را برای به حداقل رساندن فرصت حملات تنظیم کنید.
- پیاده‌سازی ثبت وقایع و نظارت: فعالیت جلسه را پیگیری کنید تا رفتارهای مشکوک را شناسایی و به آنها پاسخ دهید.



با درک شناسه‌های جلسه و اجرای بهترین شیوه‌ها، توسعه‌دهندگان می‌توانند امنیت و قابلیت استفاده برنامه‌های وب خود را افزایش دهند.

session fixation چیست؟

تثبیت جلسه نوعی حمله است که در آن مهاجم کاربر را فریب می‌دهد تا از یک شناسه جلسه شناخته شده استفاده کند و به مهاجم اجازه می‌دهد جلسه کاربر را بدزدد.

نحوه عملکرد

۱. **تنظیم شناسه جلسه:** مهاجم ابتدا یک جلسه در برنامه وب هدف ایجاد می‌کند و یک شناسه جلسه به دست می‌آورد. سپس این شناسه جلسه را از طریق روش‌های مختلف، مانند یک لینک یا ایمیل فیشینگ، برای قربانی ارسال می‌کند.
۲. **تعامل کاربر:** قربانی روی لینک کلیک می‌کند که ممکن است او را به صفحه ورود به سیستم هدایت کند که در آن شناسه جلسه در مرورگر کاربر تنظیم شده است.
۳. **ورود کاربر:** هنگامی که قربانی وارد سیستم می‌شود، برنامه وب، جلسه احراز هویت شده قربانی را با شناسه جلسه از پیش تعیین شده مهاجم مرتبط می‌کند.
۴. **دسترسی مهاجم:** پس از ورود کاربر، مهاجم می‌تواند از همان شناسه جلسه برای جعل هویت قربانی و دسترسی به حساب یا داده‌های او استفاده کند.



مثال همراه با سناریو

- مهاجم لینکی را به وبسایتی با شناسه نشست ثابت در URL برای قربانی ارسال می کند.
- قربانی روی لینک کلیک کرده و بدون اطلاع از شناسه نشست مهاجم وارد سیستم می شود.
- مهاجم اکنون می تواند از همان شناسه نشست برای انجام اقداماتی استفاده کند که گویی خود قربانی است.

اقدامات پیشگیرانه

۱. بازیابی شناسه های جلسه: سرور باید پس از ورود موفقیت آمیز، یک شناسه جلسه جدید ایجاد کند. این کار تضمین می کند که شناسه جلسه مرتبط با کاربر وارد شده منحصر به فرد است و توسط مهاجم کنترل نمی شود.
۲. استفاده از کوکی های امن: پیاده سازی ویژگی هایی مانند «فقط Http» و «امن» روی کوکی ها می تواند به محافظت از شناسه های جلسه در برابر دسترسی از طریق جاوا اسکریپت یا انتقال از طریق اتصالات ناایمن کمک کند.
۳. زمان های پایان جلسه: تنظیم زمان پایان برای جلسات می تواند فرصت مهاجم برای سوءاستفاده از یک جلسه ثابت را محدود کند.
۴. بررسی های اعتبارسنجی: بررسی های اضافی را اجرا کنید تا اطمینان حاصل شود که شناسه های جلسه نه تنها معتبر هستند، بلکه با اعتبارنامه ها و رفتارهای کاربر نیز مرتبط هستند.
۵. آگاهی کاربر: آموزش کاربران در مورد تلاش های احتمالی فیشینگ و اهمیت ایمن سازی جلسات آنها می تواند به کاهش خطر چنین حملاتی کمک کند. با درک تثبیت نشست و اجرای این اقدامات پیشگیرانه، توسعه دهندگان می توانند امنیت برنامه های وب را به میزان قابل توجهی افزایش داده و کاربران را از ربودن نشست محافظت کنند.



بررسی تفاوت بین session hijacking و session fixation

تثبیت نشست و ربودن نشست هر دو نوع حمله‌ای هستند که نشست‌های کاربر را در برنامه‌های وب هدف قرار می‌دهند، اما به روش‌های مختلفی عمل می‌کنند. در اینجا به تفصیل تفاوت‌های کلیدی آنها آمده است:

Session Fixation

۱. تعریف: در تثبیت جلسه، مهاجم کاربر را فریب می‌دهد تا از یک شناسه جلسه خاص که مهاجم کنترل می‌کند استفاده کند. مهاجم از قبل یک جلسه تنظیم می‌کند و سپس قربانی را مجبور به استفاده از آن شناسه جلسه می‌کند.

۲. مکانیسم:

- مهاجم یک جلسه ایجاد می‌کند و یک شناسه جلسه به دست می‌آورد.
- مهاجم این شناسه جلسه را برای قربانی ارسال می‌کند، اغلب از طریق یک URL یا لینک فیشینگ.
- وقتی قربانی با استفاده از این شناسه جلسه وارد سیستم می‌شود، آنها ناآگاهانه با جلسه مهاجم احراز هویت می‌شوند و به مهاجم اجازه می‌دهند به جلسه کاربر دسترسی پیدا کند.

۳. نقش مهاجم: مهاجم نقش فعالی در تنظیم شناسه جلسه‌ای که قربانی استفاده خواهد کرد، ایفا می‌کند.

۴. هدف: هدف این است که قربانی را وادار به احراز هویت با شناسه جلسه‌ای کند که مهاجم از قبل می‌داند و به مهاجم اجازه می‌دهد پس از ورود، کنترل را به دست گیرد.



Session Hijacking

۱. تعریف: در ربودن جلسه، مهاجم با دزدیدن یا رهگیری یک شناسه جلسه معتبر، کنترل یک جلسه موجود را به دست می‌گیرد. این می‌تواند از طریق روش‌های مختلفی مانند شنود شبکه، اسکریپت‌نویسی بین سایتی (XSS) یا حملات مرد میانی اتفاق بیفتد.

۲. مکانیسم:

- مهاجم در حالی که کاربر وارد سیستم شده است، اغلب با رهگیری ترافیک شبکه یا سوءاستفاده از آسیب‌پذیری‌ها، یک شناسه جلسه معتبر را به دست می‌آورد.
- هنگامی که مهاجم شناسه جلسه را دارد، می‌تواند خود را به جای کاربر جا بزند و به حساب یا داده‌های او دسترسی غیرمجاز پیدا کند.

۳. نقش مهاجم: نقش مهاجم منفعل‌تر است؛ آنها به جای ایجاد یک جلسه برای قربانی، یک جلسه از قبل ایجاد شده را به دست می‌گیرند.

۴. هدف: هدف سوءاستفاده از یک جلسه موجود با دزدیدن شناسه جلسه است که به مهاجم اجازه می‌دهد بدون نیاز به فریب کاربر برای استفاده از یک شناسه خاص، به آن دسترسی پیدا کند.



خلاصه تفاوت ها :

ویژگی	تثبیت نشست (Session Fixation)	ربودن نشست (Session Hijacking)
نقش مهاجم	فعالانه یک شناسه نشست برای قربانی تنظیم می کند	غیرفعالانه یک شناسه نشست موجود را می دزدد
نحوه عملکرد	فریب کاربر برای استفاده از یک شناسه نشست ثابت	رهگیری یا سرقت شناسه نشست فعال
تعامل کاربر	قربانی از شناسه نشست مهاجم استفاده می کند	نشست قربانی بدون اطلاع وی به خطر می افتد
مثال روش حمله	لینک فیشینگ همراه با شناسه نشست ثابت	اسنیفینگ شبکه یا حمله XSS

نتیجه گیری

هر دو حمله از آسیب پذیری های مربوط به مدیریت نشست سوءاستفاده می کنند، اما از تاکتیک ها و مکانیسم های متفاوتی استفاده می کنند. درک این تفاوت ها برای پیاده سازی اقدامات امنیتی مؤثر برای محافظت در برابر هر دو نوع تهدید بسیار مهم است.